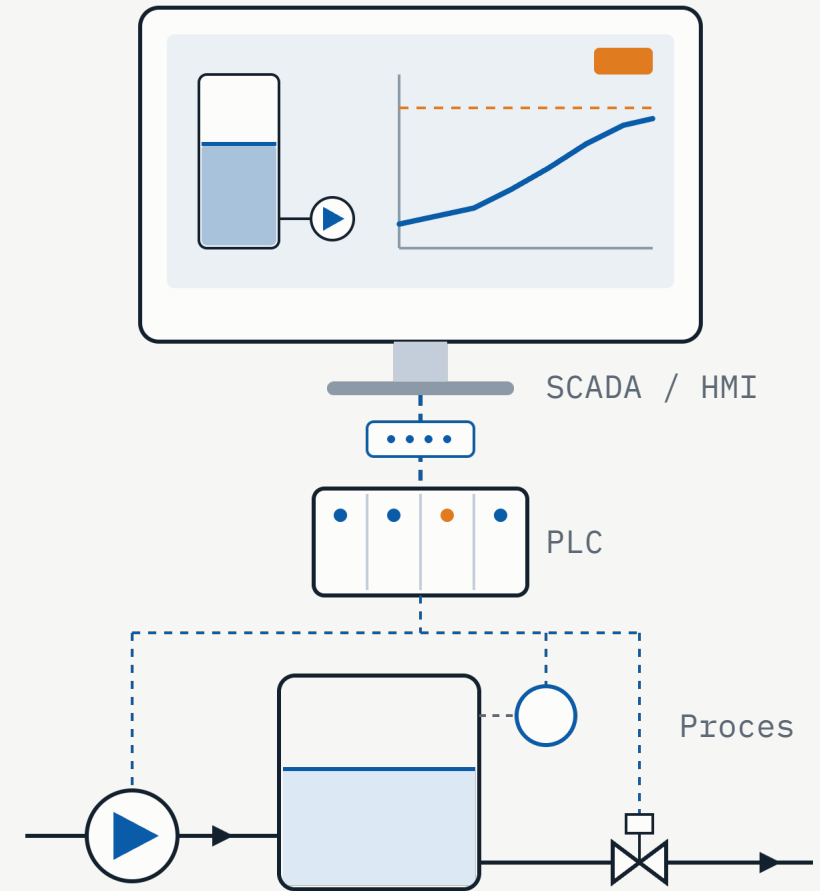


SCADA sistemi

Arhitektura, procesi, prikazi, konfiguracija i bezbednost
nadzorno-upravljačkih sistema

Teorijske osnove i primena u projektu



Sadržaj prezentacije

01

Arhitektura

Komponente, Purdue model, akvizicija, protokoli i softverska organizacija.

07–14

02

Procesi

Upravljačka petlja, modelovanje, tagovi, alarmi, komande i historian.

15–26

03

Prikazi

Uloga HMI-ja, hijerarhija prikaza, trendovi i kodiranje stanja.

27–34

04

Konfiguracija

Inženjering, adresiranje, konfiguracija kao kod, uloge i testiranje.

35–40

05

Bezbednost

Pretnje, napadi na protokole, odbrana u dubinu, detekcija i odgovor.

41–52

Uvod · pojam, razvoj i primena SCADA sistema (03–06)

Završni deo · veza sa projektom, zaključak i pojmovnik (53–56)

Pojam SCADA sistema

SCADA (engl. *Supervisory Control and Data Acquisition*) jeste klasa sistema za nadzor i upravljanje raspodeljenim fizičkim procesima.



Akvizicija podataka

Prikupljanje merenja i stanja opreme sa terena.



Nadzor

Prikaz stanja operateru, alarmi, trendovi i istorija.



Nadzorno upravljanje

Promena zadatih vrednosti i režima, dok brze petlje zatvaraju lokalni kontroleri.

KARAKTERISTIKE

Geografska raspodeljenost

Od jednog postrojenja do mreže koja pokriva region.

Rad u realnom vremenu

Podaci i komande sa predvidivim kašnjenjem.

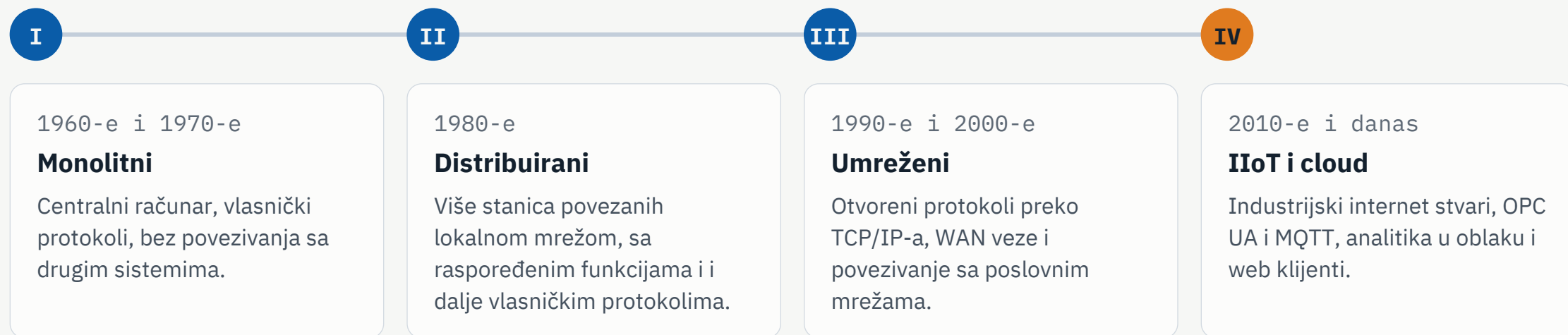
Dug životni vek

Oprema radi decenijama, uz nasleđene protokole.

Heterogenost

Uređaji i protokoli različitih proizvođača.

Razvoj SCADA sistema kroz generacije



 Svaka generacija povećala je povezanost, a time i površinu napada: izolacija više nije realna pretpostavka.

Primena u infrastrukturnim sistemima



Elektroenergetika

Proizvodnja, prenos i distribucija, uz daljinsko upravljanje trafostanicama.



Vodosnabdevanje

Pumpne stanice, rezervoari i prečišćavanje vode i otpadnih voda.



Nafta i gas

Cevovodi i kompresorske stanice na velikim udaljenostima.



Industrijska proizvodnja

Proizvodne linije, šaržni procesi i praćenje kvaliteta.



Saobraćaj

Tuneli, železnička signalizacija i upravljanje saobraćajem.



Grejanje i HVAC

Toplane, toplovodna mreža i upravljanje objektima.



Zajednička osobina: posledice kvara ili napada su fizičke — prekid usluge, oštećenje opreme, ugrožavanje okoline i ljudi.

SCADA, DCS i PLC: razgraničenje

Obeležje	SCADA	DCS	PLC
Primarna namena	Nadzor i prikupljanje podataka	Upravljanje procesom u postrojenju	Lokalno upravljanje mašinom ili celinom
Prostorni obuhvat	Geografski raspodeljen	Jedno postrojenje	Jedna mašina ili linija
Način upravljanja	Nadzorno, preko kontrolera	Neposredno, kontinualno	Logičko i sekvencijalno
Tipična primena	Elektro mreža, vodovod, cevovodi	Rafinerije, hemijska industrija	Proizvodne linije, pakovanje
Vremenska skala	Sekunde	Delovi sekunde	Milisekunde (ciklus skeniranja)

Granice se danas zamagljuju: SCADA koristi PLC-ove kao terenske kontrolere, a DCS preuzima funkcije nadzora šireg područja.

01

DEO PRVI

Arhitektura

Od fizičkih komponenti i mrežnih nivoa do softverske organizacije savremene SCADA platforme.

Komponente

Purdue model

Akvizicija podataka

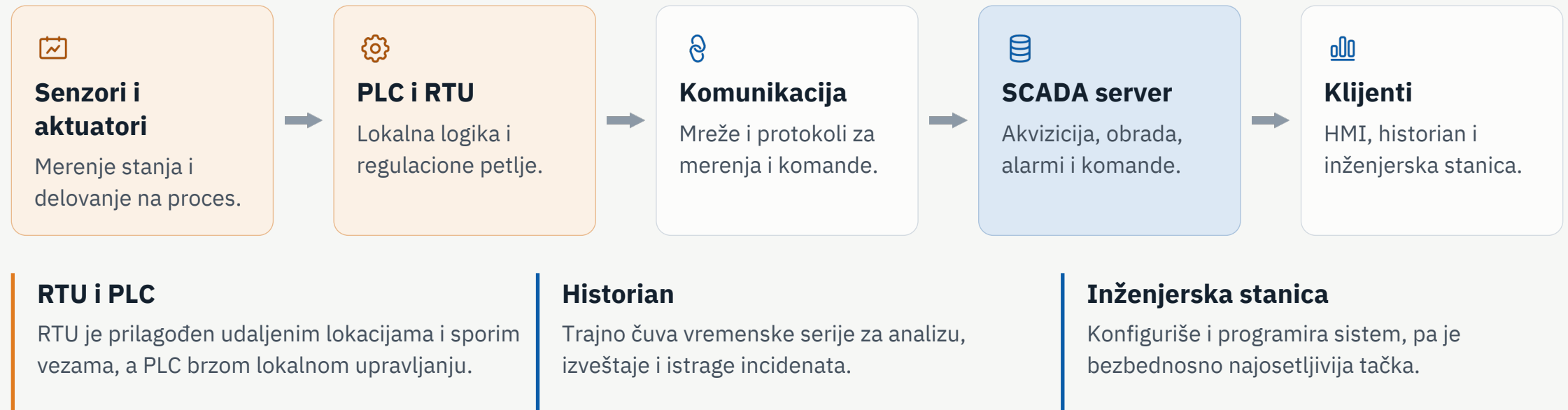
Protokoli

Dostupnost

Softverska arhitektura

Modularnost

Komponente SCADA sistema



Purdue referentni model

Nivo 5	Korporativna mreža	ERP, e-pošta, pristup internetu
Nivo 4	Poslovna logistika	Planiranje i poslovni sistemi lokacije
DMZ	Industrijska DMZ	Replika historiana, posrednici, ažuriranja
Nivo 3	Operacije postrojenja	Historian, MES, upravljanje proizvodnjom
Nivo 2	Nadzor	SCADA server, HMI, alarmi
Nivo 1	Osnovno upravljanje	PLC, RTU, kontroleri
Nivo 0	Fizički proces	Senzori, aktuatori, oprema

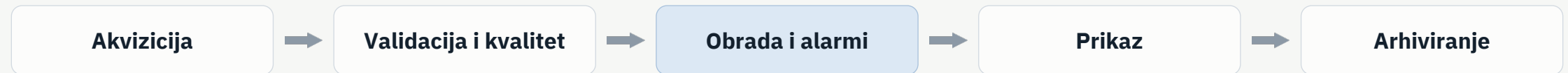
IT zona nivoi 4 i 5

OT zona nivoi 0 do 3

Saobraćaj između IT i OT zone prolazi isključivo kroz DMZ. Neposredna veza nije dozvoljena.

Model je osnova za segmentaciju mreže prema NIST SP 800-82 i IEC 62443.

Tok podataka i načini akvizicije



🕒 Ciklična prozivka

Server periodično proziva svaki uređaj (engl. *polling*).

- Predvidivo opterećenje mreže
- Kašnjenje do jednog ciklusa prozivke
- Jednostavna detekcija nedostupnog uređaja

⚡ Izveštavanje o promeni

Uređaj šalje samo značajne promene (engl. *report by exception*).

- Manji saobraćaj pri stabilnom procesu
- Promena se prijavljuje odmah
- Potreban periodični upit integriteta

Industrijski komunikacioni protokoli

Protokol	Tipičan domen	Model komunikacije	Bezbednost
Modbus	Opšta industrija	Master–slave, registri	Bez ugrađene autentifikacije
DNP3	Elektroenergetika, vodovod	Master–outstation, događaji	Secure Authentication, opciono
IEC 60870-5-104	Telekomanda u energetici	Klijent–server preko TCP/IP	Dopuna standardom IEC 62351
IEC 61850	Automatizacija trafostanica	Objektni model, MMS, GOOSE	Dopuna standardom IEC 62351
OPC UA	Interoperabilnost, IIoT	Klijent–server i pub/sub	Ugrađeno: sertifikati, potpis, šifrovanje
MQTT	Telemetrija, IIoT	Publish/subscribe preko brokera	TLS i autentifikacija na brokeru

Stariji protokoli nastali su kada se mreža smatrala zatvorenom, pa se poverenje podrazumevalo.

Dostupnost kao prvi prioritet

IT SISTEMI

1 · Poverljivost

2 · Integritet

3 · Dostupnost

OT / SCADA

1 · Dostupnost

2 · Integritet

3 · Poverljivost

Iznad svih ciljeva u OT okruženju stoji bezbednost ljudi i okoline (engl. *safety*).

Redundantni serveri

Rezervni server preuzima rad bez prekida nadzora.

Redundantne mreže

Dvostruke komunikacione putanje do kontrolera.

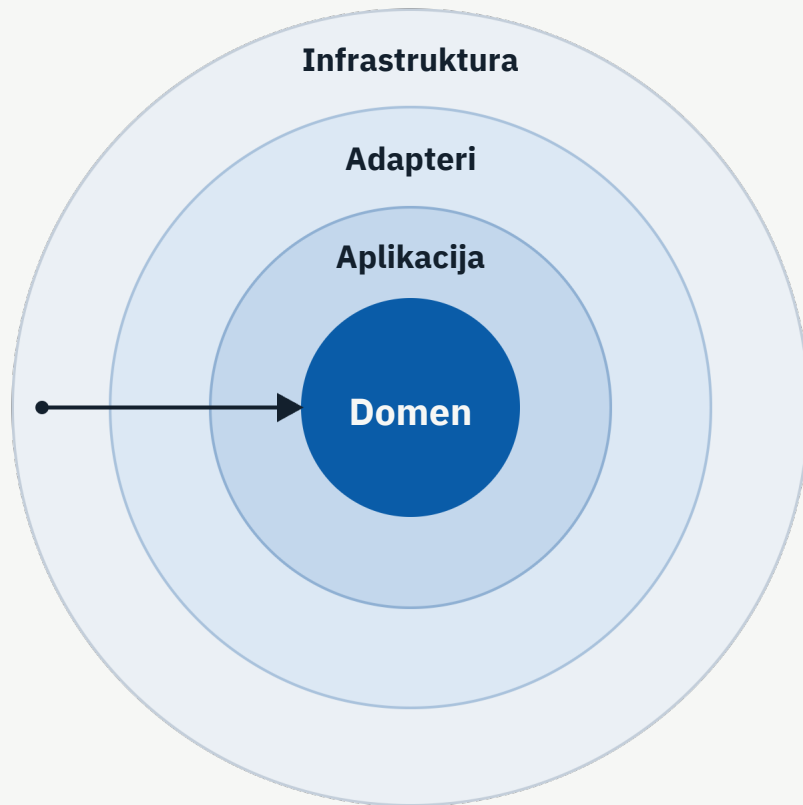
Lokalna autonomija

Kontroleri nastavljaju rad i kada je veza sa SCADA serverom prekinuta.

Planirane izmene

Zakrpe i ponovna pokretanja zahtevaju planirane zastoje i prethodno testiranje.

Softverska arhitektura SCADA platforme



Domen

Tagovi, alarmi, komande i pravila procesa, bez tehnoloških zavisnosti.

Aplikacija

Slučajevi korišćenja, autorizacija i transakcije.

Adapteri

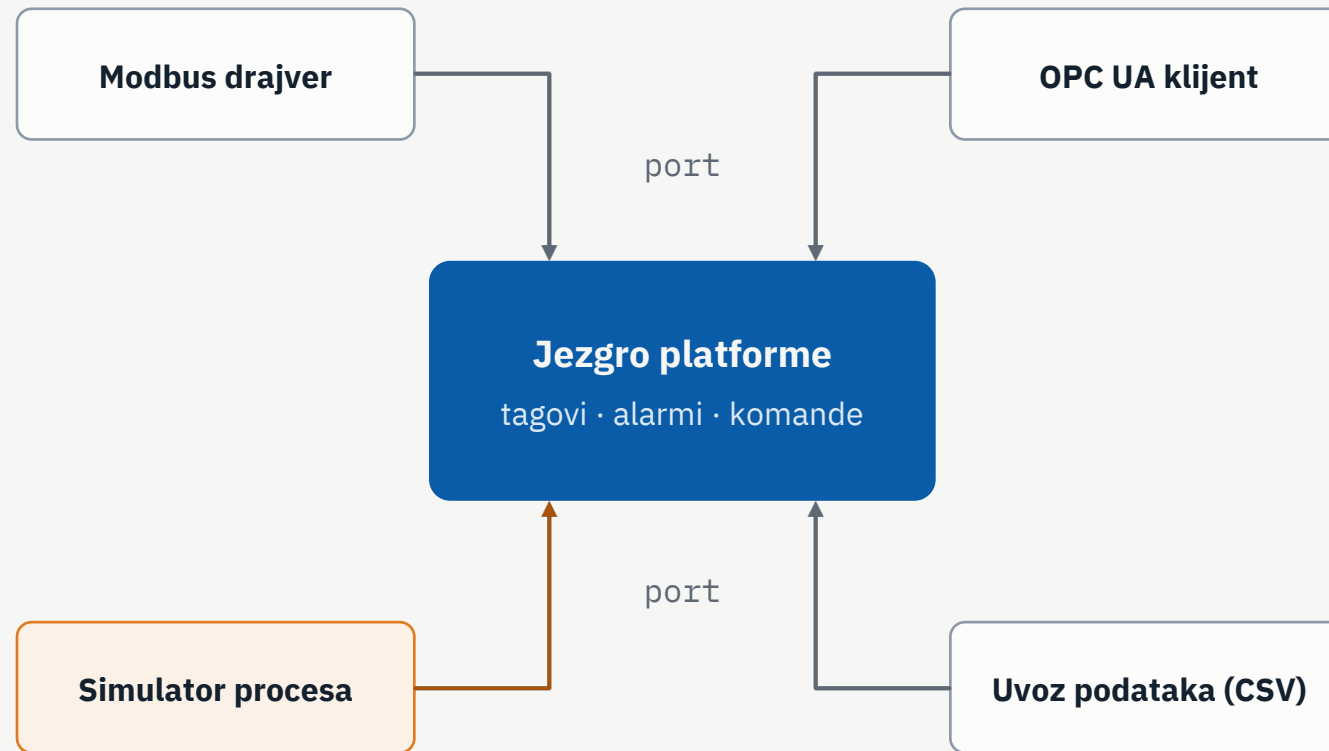
Web API, drajveri protokola i repozitorijumi.

Infrastruktura

Baza podataka, mreža i operativno okruženje.

Zavisnosti su usmerene ka središtu: zamena baze ili protokola ne menja pravila procesa.

Modularnost: drajveri i adapteri



Jezgro definiše **jedinstven ugovor** (port), a svaki izvor podataka priključuje se kao adapter koji ga implementira.

Otvorenost za proširenje

Nov protokol ili proces dodaje se bez izmene jezgra.

Zamenljivost

Simulator i stvarni uređaj su za jezgro ravnopravni izvori.

02

DEO DRUGI

Procesi

Kako se fizički proces predstavlja, upravlja i nadzire: od regulacione petlje do alarma, komandi i istorijskih podataka.

Vrste procesa

Upravljačka petlja

PID

Model procesa

Tagovi i kvalitet

Alarmi

Komande

Historian

Simulacija

Vrste industrijskih procesa



Kontinualni

Materijal ili energija teku bez prekida, a promjenljive se menjaju neprekidno.

Vodovod, rafinerije, elektroenergetska mreža



Diskretni

Obraduju se pojedinačni komadi, a stanje se menja na događaje.

Montaža, pakovanje, robotske ćelije



Šaržni

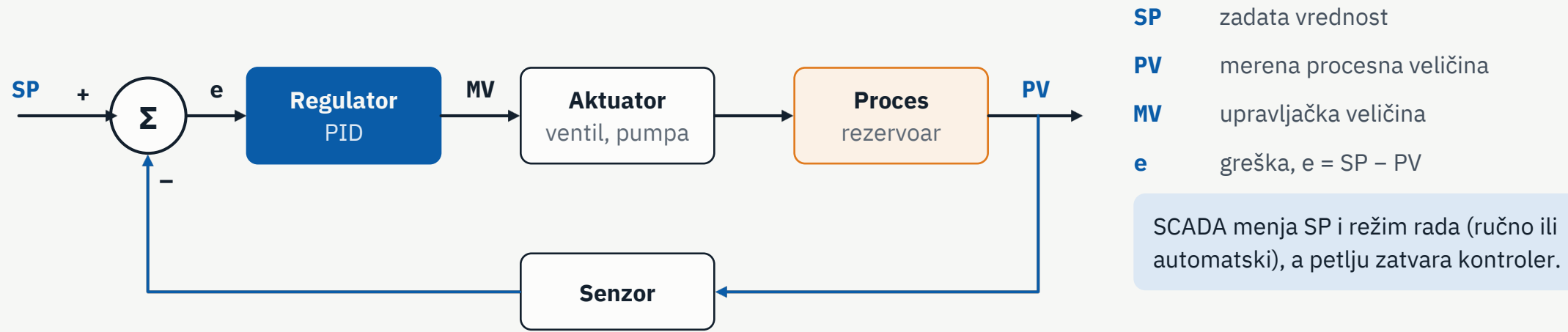
Proizvodnja u serijama prema recepturi, kroz niz faza (ISA-88).

Prehrambena, farmaceutska i hemijska industrija



Modelovanje: kontinualni procesi opisuju se diferencijalnim jednačinama, a diskretni automatima stanja i događajima.

Upravljačka petlja sa povratnom spregom



PID regulacija

$$u(t) = K_p e(t) + K_i \int_0^t e(\tau) d\tau + K_d \frac{de(t)}{dt}$$

P

Proporcionalni član

Deluje srazmerno trenutnoj grešci. Daje brz odziv, ali sam ostavlja stacionarnu grešku.

I

Integralni član

Akumulira grešku kroz vreme i uklanja stacionarnu grešku, uz rizik od preskoka.

D

Diferencijalni član

Reaguje na brzinu promene greške i prigušuje oscilacije, ali je osetljiv na šum.



Parametri K_p , K_i i K_d su bezbednosno osetljivi: njihovu izmenu sme da izvrši samo ovlašćeni inženjer, uz audit zapis.

Primer modela procesa: rezervoar

Bilans zapremine prema zakonu održanja mase, diskretizovan eksplicitnom Ojlerovom metodom:

$$\frac{dV}{dt} = Q_{in} - Q_{out}$$

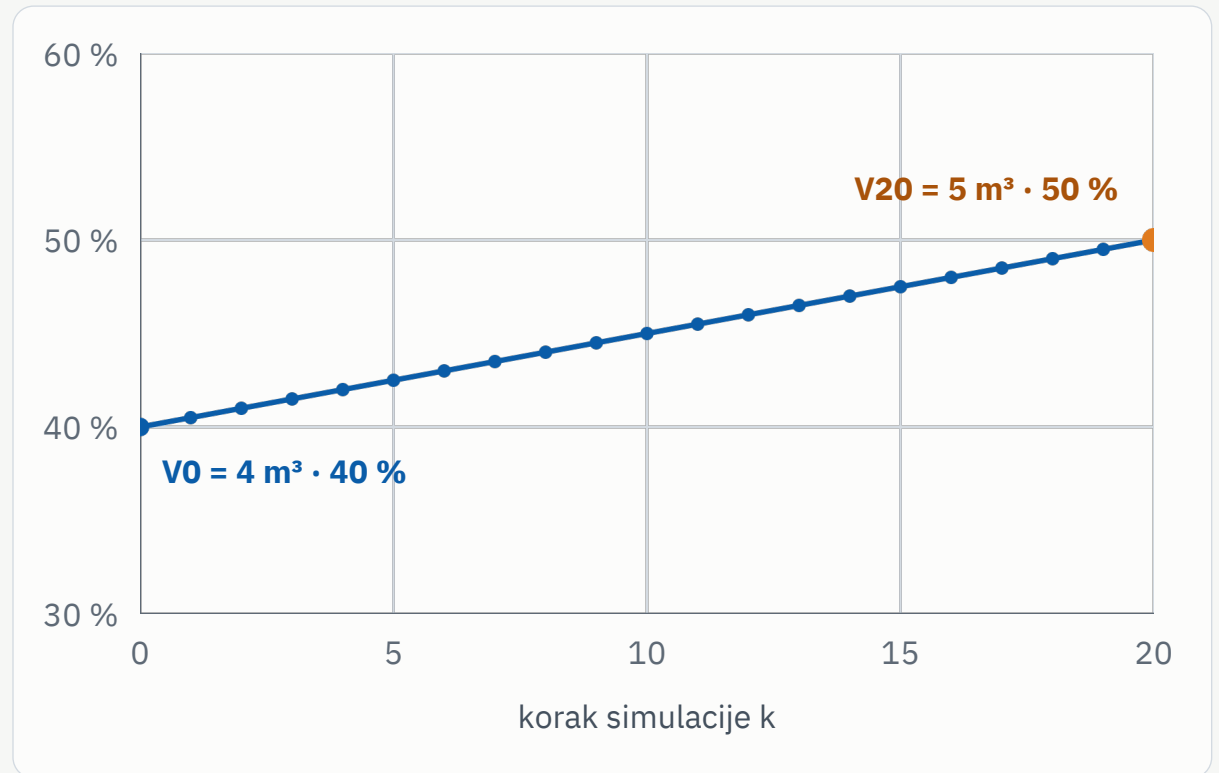
$$V_{k+1} = V_k + (Q_{in} - Q_{out}) \Delta t$$

uz ograničenje $0 \leq V_k \leq V_{max}$

$V_{max} = 10 \text{ m}^3$, $V_0 = 4 \text{ m}^3$, $Q_{in} = 0,1 \text{ m}^3/\text{s}$, $Q_{out} = 0,05 \text{ m}^3/\text{s}$, $\Delta t = 1 \text{ s}$

Posle 20 koraka: $V = 5 \text{ m}^3$, nivo 50 %

Korak Δt mora biti mali u odnosu na dinamiku procesa da bi greška diskretizacije bila prihvatljiva.



Tag: osnovna jedinica procesnih podataka

Atribut	Primer
Naziv	LT-101
Opis	Nivo u rezervoaru 1
Tip i jedinica	realan broj, %
Opseg	0–100
Pristup	samo čitanje
Izvor	PLC-1, registar 30001
Vrednost i kvalitet	52,5 · GOOD
Vremenska oznaka	2026-10-08T12:00:00Z

Imenovanje prema ISA-5.1

Prvo slovo — merena veličina: L nivo, F protok, P pritisak, T temperatura.

Naredna slova — funkcija: T prenos, I indikacija, C regulacija, A alarm. Sufiksi H i L znače visok i nizak.

LT

merni pretvarač nivoa

FIC

indikator-regulator protoka

PAH

alarm visokog pritiska

TI

indikator temperature

Kvalitet podataka i vremenske oznake

GOOD

Pouzdana vrednost

Merenje je važeće i može se koristiti bez ograničenja.

UNCERTAIN

Nesigurna vrednost

Procena, ručni unos ili senzor van kalibracije.

BAD

Neupotrebljiva vrednost

Kvar senzora, prekid veze ili vrednost van opsega.

STALE

Zastarela vrednost

Nije osvežena u dozvoljenom roku, pa je stanje procesa nepoznato.

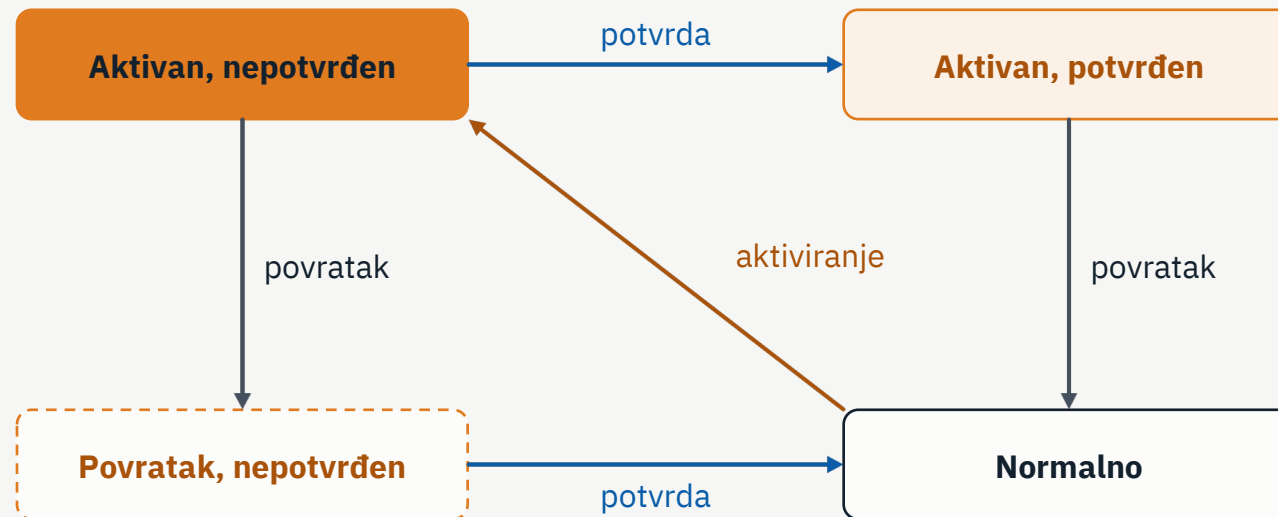
Dve vremenske oznake

Vreme nastanka na izvoru i vreme prijema na serveru (u OPC UA: *SourceTimestamp* i *ServerTimestamp*).

Redosled i celovitost

Broj sekvence otkriva izgubljene i zakasnele poruke. Starija poruka ne sme da prepiše noviju vrednost.

Alarmi: model stanja prema ISA-18.2



Dodatna stanja

Odložen — privremeno sklonjen, uz kontrolu i rok.

Potisnut projektom — po logici procesa, npr. oprema van rada.

Van upotrebe — tokom održavanja.

Alarm je obaveštenje koje zahteva reakciju operatera. Ako reakcija nije potrebna, to nije alarm.

Upravljanje alarmima i preplavljivanje

Histereza (mrtva zona)

Alarm na 85 % prestaje tek ispod 80 %, pa ne treperi oko praga.

Odloženo aktiviranje

Uslov mora trajati zadato vreme, pa se kratki prelasci zanemaruju.

Potiskivanje posledičnih alarma

Jedan uzrok ne sme da izazove lavinu zavisnih alarma.

Racionalizacija

Za svaki alarm dokumentuju se uzrok, posledica, prioritet i propisana reakcija.

~150

alarma dnevno po operateru: vrlo verovatno prihvatljivo

> 10

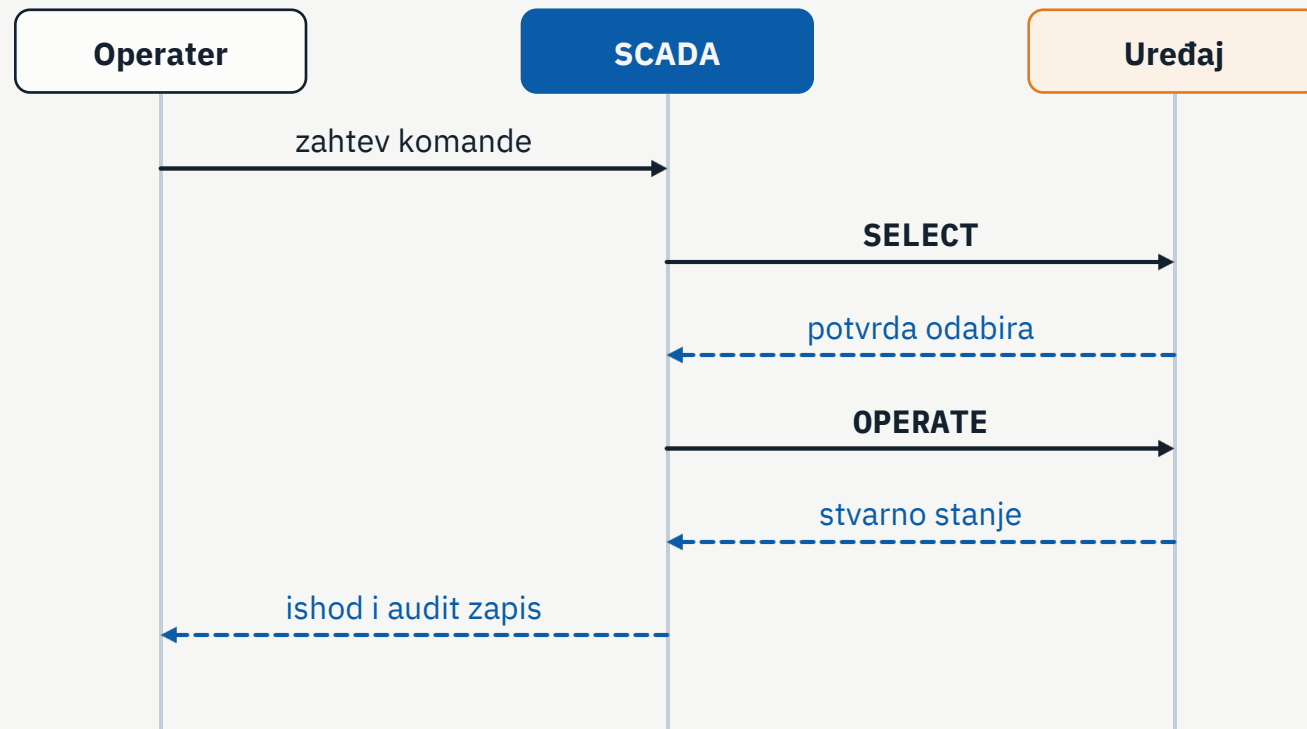
alarma u 10 minuta: preplavljivanje (engl. *alarm flood*)

80/15/5

% raspodela nizak, srednji i visok prioritet

Orijentacione vrednosti prema ANSI/ISA-18.2.

Upravljačke komande: odabir pa izvršenje



Pre izvršenja

Identitet i ovlašćenje, interlock, dozvoljeno stanje i opseg vrednosti.

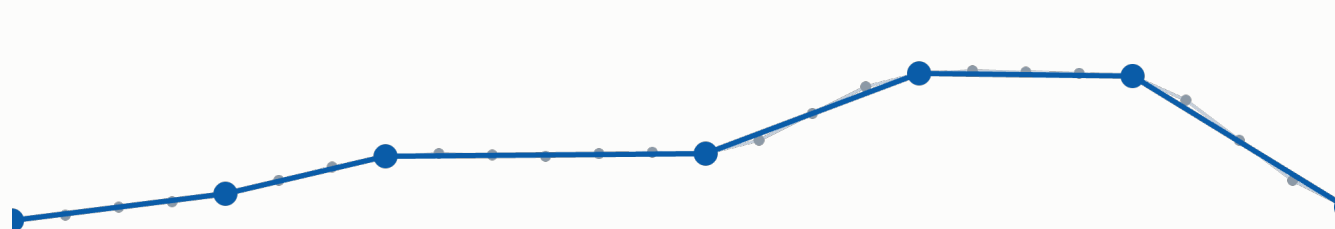
Posle izvršenja

Uspeh se potvrđuje stvarnim stanjem uređaja, a ne samo prijemom komande.

Bez dvostrukog efekta

Ponovljen zahtev ne sme dva puta izvršiti istu akciju.

Historian: čuvanje vremenskih serija



● sirovi uzorci: 26

● **sačuvane tačke: 7**

Signal se rekonstruiše linearnom interpolacijom u zadatoj toleranciji. Primer je ilustrativan.

Kompresija

Mrtva zona i algoritam „vrata koja se njišu” (engl. *swinging door*).

Agregati i upiti

Minimum, maksimum, prosek i interpolacija nad vremenskim intervalom.

Integritet

Zapisi se naknadno ne menjaju, jer je istorija osnova za forenzičku analizu.

Simulacija procesa i ispitna okruženja



Obuka operatera

Uvežbavanje nenormalnih situacija bez rizika po postrojenje.



Testiranje konfiguracije

Provera tagova, alarma i ekrana pre puštanja u rad.



Bezbednosna istraživanja

Napadi i odbrana analiziraju se na modelu, a ne na stvarnoj infrastrukturi.



Reprodukcija događaja

Ponavljanje zabeleženih podataka radi analize incidenata.



Ispitna postrojenja poput SWaT (Singapur) objavljuju podatke o normalnom radu i napadima, što je tema sledeće prezentacije.

03

DEO TREĆI

Prikazi

Interfejs čovek–mašina kao sredstvo situacione svesti: hijerarhija prikaza, principi projektovanja i vizuelno kodiranje stanja.

Uloga HMI-ja

Hijerarhija prikaza

Visokoperformantni HMI

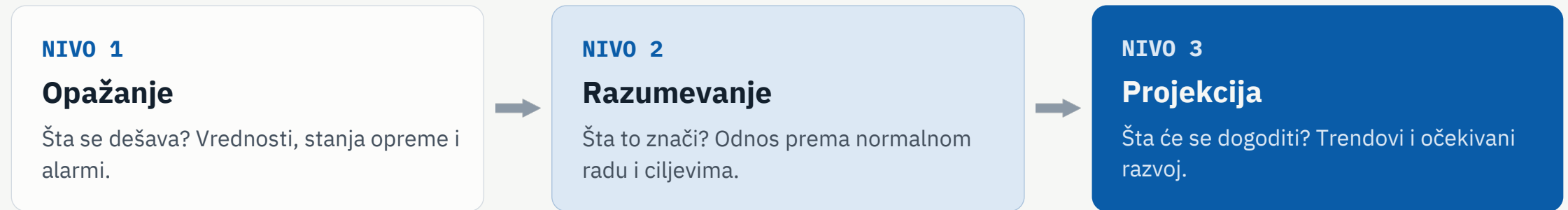
Elementi prikaza

Kodiranje stanja

Trendovi

Raspored ekrana

HMI i situaciona svest operatera



HMI nije samo slika procesa. Obuhvata:

procesne prikaze

navigaciju

alarme

trendove

komande i potvrde

povratne informacije

Model situacione svesti prema: M. R. Endsley, 1995.

Hijerarhija prikaza prema ISA-101



Nivo 1

Celo područje odgovornosti i ključni pokazatelji na jednom ekranu.

Nivo 2

Svakodnevni rad sa procesnom jedinicom.

Nivo 3

Pojedinosti opreme i upravljački paneli.

Nivo 4

Dijagnostika, procedure i pomoćne informacije.

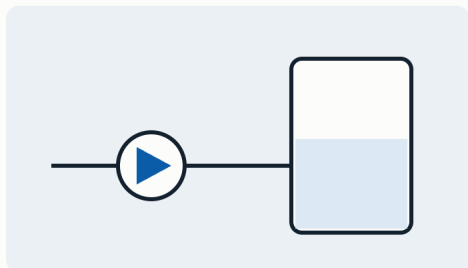
Tradicionalni i visokoperformantni HMI

Obeležje	Tradicionalni pristup	Visokoperformantni pristup
Pozadina	Tamna, uz mnogo živih boja	Svetla i neutralna, siva
Upotreba boje	Dekoratívna, boja opisuje stanje opreme	Rezervisana za odstupanja i alarme
Prikaz vrednosti	Brojevi bez konteksta	Analogni indikatori sa normalnim opsegom
Grafika	Realistične i trodimenzionalne slike	Pojednostavljeni dvodimenzionalni simboli
Alarmi	Nedosledne boje i oblici	Dosledno kodiranje prioriteta



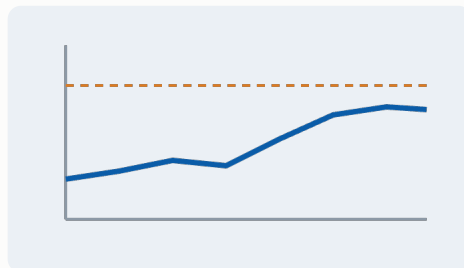
Princip: kada je proces normalan, ekran je miran, a pažnju privlači samo ono što odstupa.

Osnovni elementi SCADA prikaza



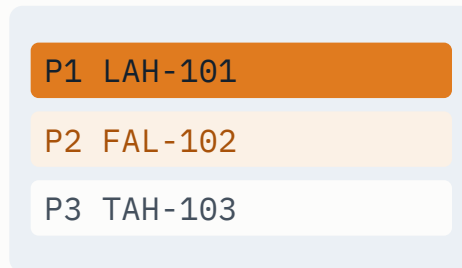
Procesna šema

Simboli opreme vezani za tagove u stvarnom vremenu.



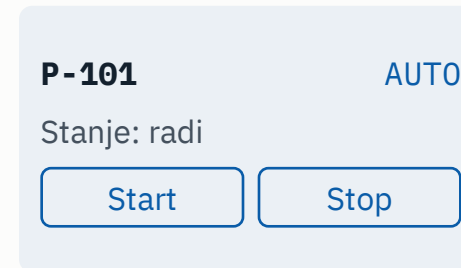
Trend

Vrednost kroz vreme, sa granicama i kvalitetom.



Alarmni panel

Aktivni alarmi po prioritetu, uz potvrđivanje.



Upravljački panel

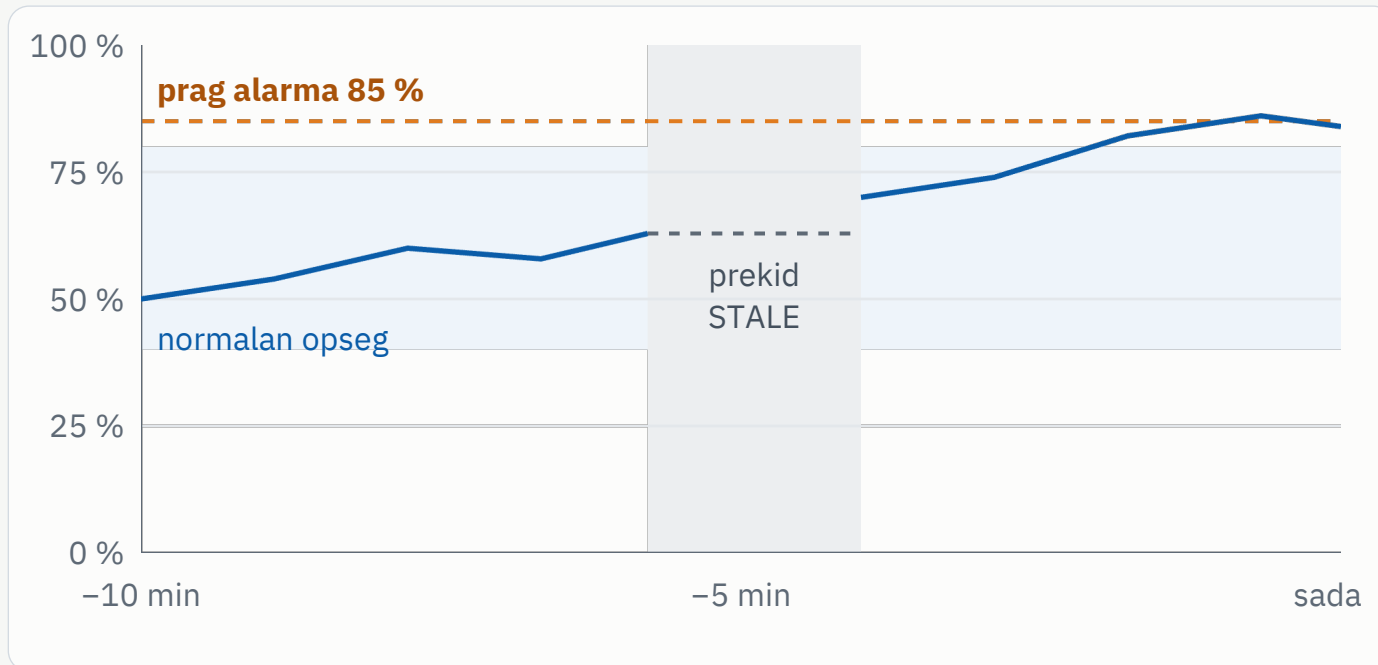
Stanje, režim i komande jednog uređaja.

Vizuelno kodiranje stanja i kvaliteta

- 01** Neutralna, svetla pozadina, a boja je rezervisana za odstupanja i alarme.
- 02** Stanje se nikada ne iskazuje samo bojom, već i tekstom, oblikom ili okvirom.
- 03** Kvalitet podatka prati vrednost na svakom mestu gde se ona prikazuje.
- 04** Prioritet alarma kodiran je doslednom bojom i tekstualnom oznakom.
- 05** Plava i narandžasta razlikuju se i po svetlini, pa ostaju čitljive i na projektoru.



Trend: vrednost u kontekstu vremena



Trend pokazuje smer i brzinu promene, ne samo trenutnu vrednost.

Kontekst

Normalni opseg i pragovi alarma na istom grafikonu.

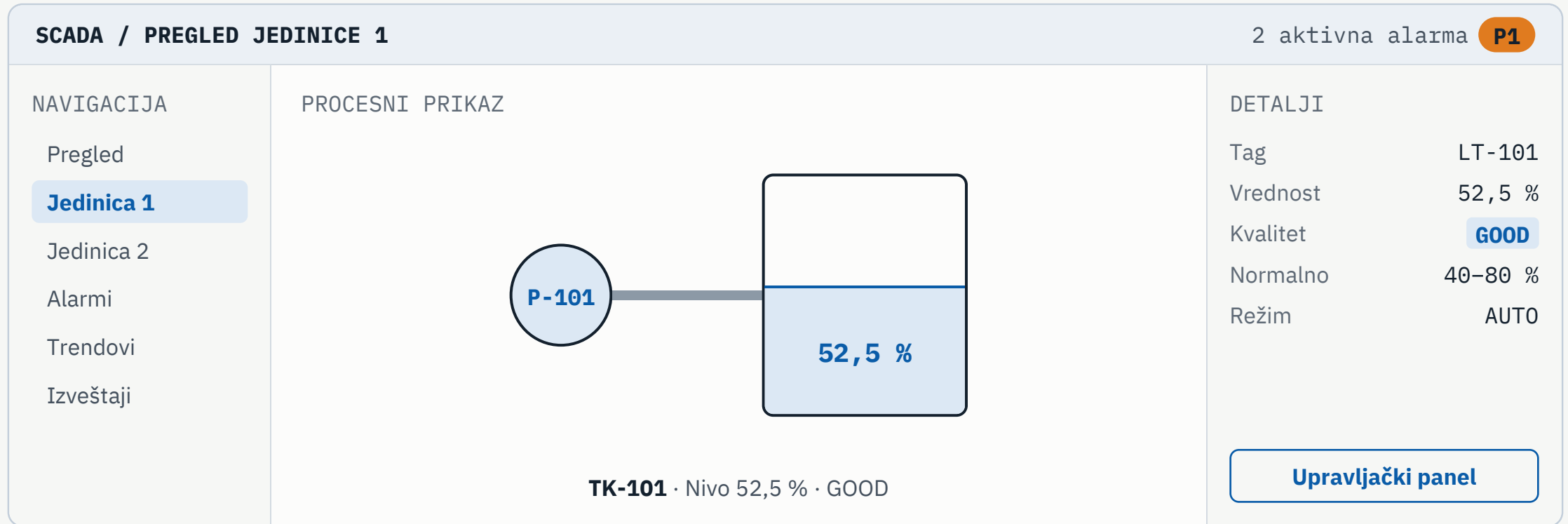
Iskrenost podataka

Prekid se prikazuje kao prekid, a ne kao ravna linija.

Analiza

Više signala, izbor intervala i izvoz podataka.

Raspored radnog ekrana operatera



Ilustrativni raspored: navigacija, procesni prikaz i detalji izabranog elementa, uz stalno vidljiv sažetak alarma.

04

DEO ČETVRTI

Konfiguracija

Inženjering SCADA sistema od definisanja uređaja do puštanja u rad, uz kontrolu pristupa i testiranje.

Inženjering

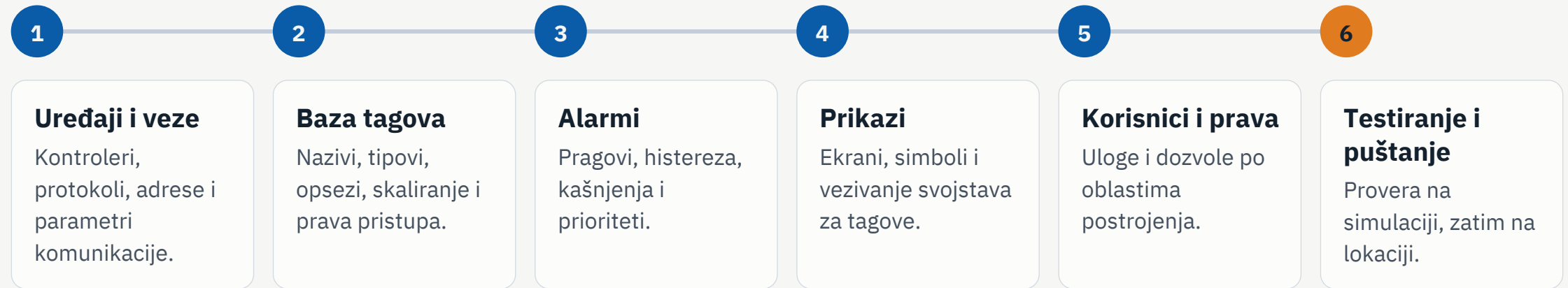
Adresiranje

Konfiguracija kao kod

Kontrola pristupa

Testiranje

Tok inženjeringa SCADA sistema



Svaka izmena konfiguracije ima autora, razlog, verziju i trag u revizionom zapisu (upravljanje izmenama).

Mapiranje tagova na adrese uređaja

Tag	Opis	Modbus adresa	Tip	Skaliranje
LT-101	nivo u rezervoaru	30001 · ulazni registar	UINT16	0–4095 → 0–100 %
FT-101	ulazni protok	30002 · ulazni registar	UINT16	0–4095 → 0–0,2 m³/s
P-101.RUN	pumpa radi	10001 · diskretni ulaz	BOOL	—
P-101.CMD	start i stop	00001 · coil	BOOL	komanda
XV-101.SP	zadata otvorenost	40001 · holding registar	UINT16	0–1000 → 0–100 %

Linearno skaliranje sirove vrednosti

$$y = y_{\min} + (x - x_{\min}) \cdot \frac{y_{\max} - y_{\min}}{x_{\max} - x_{\min}}$$

$$x = 2048 \rightarrow y \approx 50,0 \%$$



Pogrešna adresa ili skaliranje daju uverljivu, ali netačnu vrednost, pa se mapiranje proverava pri prihvatanju.

Konfiguracija kao kod

```
tags/LT-101.json
{
  "schemaVersion": "1.0",
  "tag": "LT-101",
  "type": "float",
  "unit": "%",
  "range": [0, 100],
  "source": {"device": "PLC-1", "address": 30001},
  "alarms": [
    {"type": "high", "setpoint": 85, "deadband": 5}
  ]
}
```

Verzisionisanje

Svaka izmena ima autora, opis i mogućnost povratka.

Šema i validacija

Neispravna ili nepoznata verzija odbija se pre primene.

Ponovljivost

Isto okruženje podiže se iz iste konfiguracije.

Tajne odvojeno

Lozinke i ključevi nikada nisu deo verzionisane konfiguracije.

Kontrola pristupa zasnovana na ulogama

Uloga	Tipična prava	Bez prava na
Posmatrač	Pregled prikaza, trendova i alarma	Komande i potvrdu alarma
Operater	Potvrda alarma i dozvoljene komande	Izmenu konfiguracije
Inženjer	Konfiguracija tagova, alarma i prikaza	Upravljanje nalogima
Administrator	Nalozi, uloge i nadzor platforme	Zaobilaženje kontrola procesa

Najmanje privilegije

Samo prava potrebna za posao.

Razdvajanje dužnosti

Konfiguracija i rad su odvojeni.

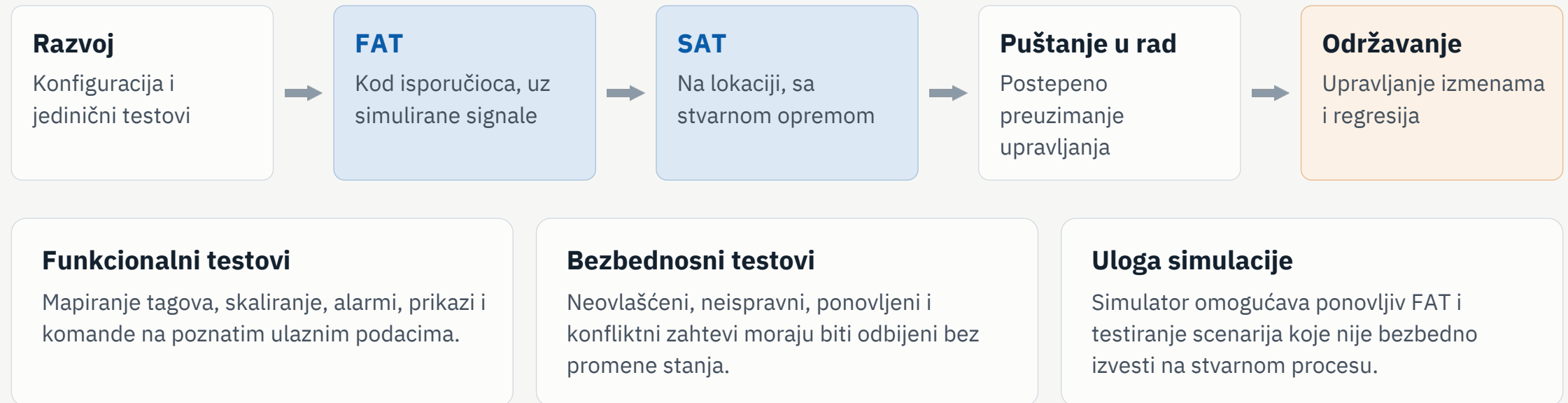
Provera na serveru

Skriveno dugme nije zaštita.

Revizioni zapis

I odbijeni pokušaji se beleže.

Testiranje i puštanje u rad



05

DEO PETI

Bezbednost

Specifičnosti zaštite operativne tehnologije, pretnje i vektori napada, odbrana u dubinu, detekcija i odgovor na incidente.

Specifičnosti OT

Vektori napada

Napadi na protokole

ATT&CK for ICS

Zone i kanali

Odbrana u dubinu

Detekcija anomalija

Ranjivosti

Incidenti

Odgovor na incidente

Regulativa

Specifičnosti bezbednosti OT okruženja

Obeležje	IT sistemi	OT i SCADA sistemi
Životni vek	3 do 5 godina	15 do 20 godina i duže
Zakrpe	Redovne, često automatske	Retke, uz planiran zastoj i prethodno testiranje
Vremenski zahtevi	Kašnjenje je uglavnom prihvatljivo	Odziv u realnom vremenu je obavezan
Protokoli	Autentifikacija i šifrovanje uobičajeni	Nasleđeni protokoli bez autentifikacije
Bezbednosni alati	Antivirus i aktivno skeniranje	Aktivno skeniranje može poremetiti uređaje
Posledica incidenta	Gubitak ili curenje podataka	Fizička šteta, prekid usluge, ugrožavanje ljudi



Mere preuzete iz IT okruženja moraju se prilagoditi, jer i sama zaštitna mera može ugroziti dostupnost procesa.

Površina napada i vektori pristupa



Udaljeni pristup

VPN veze i alati za daljinsku podršku dobavljača, često sa slabim ili deljenim lozinkama.



Poslovna mreža

Kompromitovan kancelarijski računar kao polazna tačka za prelazak u OT mrežu.



Prenosivi mediji

USB uređaji i laptopovi servisera, put kojim je Stuxnet dospeo u izolovanu mrežu.



Lanac snabdevanja

Kompromitovan softver, firmver ili ažuriranje koje isporučuje proizvođač opreme.



Izloženost internetu

Kontroleri i HMI dostupni sa javnih adresa, koje pronalaze pretraživači poput Shodana.



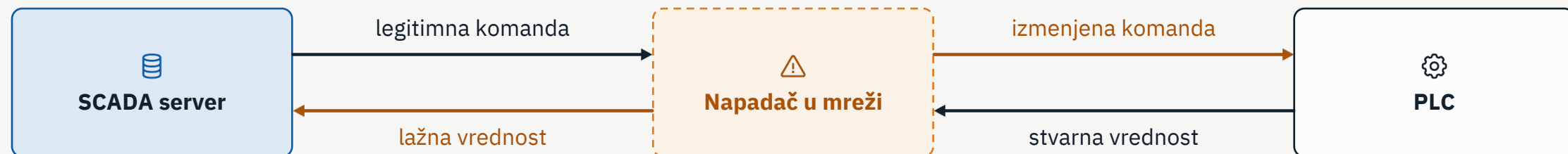
Unutrašnji akteri

Sadašnji ili bivši zaposleni i saradnici sa legitimnim pristupom i znanjem o sistemu.



Napadi na OT često počinju u IT okruženju, pa je granica između IT i OT mreže ključna linija odbrane.

Napadi na industrijske protokole



Neovlašćena komanda

Protokol bez autentifikacije prihvata upis od bilo kog učesnika.

Ponavljanje poruka

Snimljena legitimna komanda šalje se ponovo (engl. *replay*).

Čovek u sredini

Presretanje i izmena komandi i izmerenih vrednosti.

Lažni podaci

Operater vidi normalno stanje dok proces odstupa.

Uskraćivanje usluge

Preopterećenje uređaja ili prekid komunikacije.



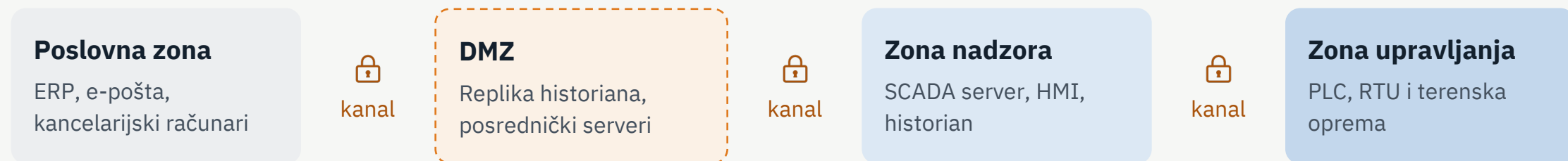
Zaštita: autentifikacija poruka (DNP3 SA, OPC UA), segmentacija, nadzor saobraćaja i provera fizičke usklađenosti vrednosti.

MITRE ATT&CK for ICS: taktike napadača

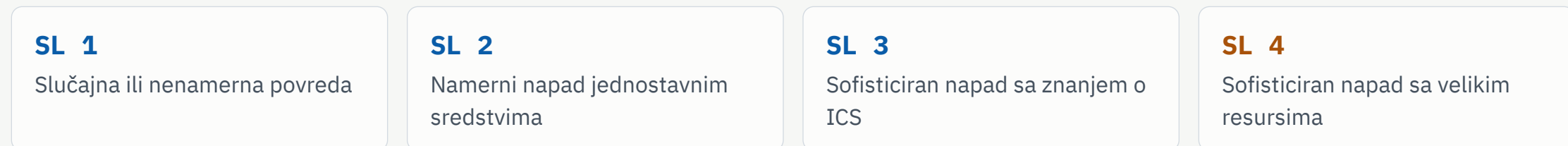


Narandžasto su označene taktike specifične za industrijske sisteme. Matrica je zasnovana na javno dokumentovanim incidentima i povezuje svaku taktiku sa tehnikama, primerima i merama zaštite.

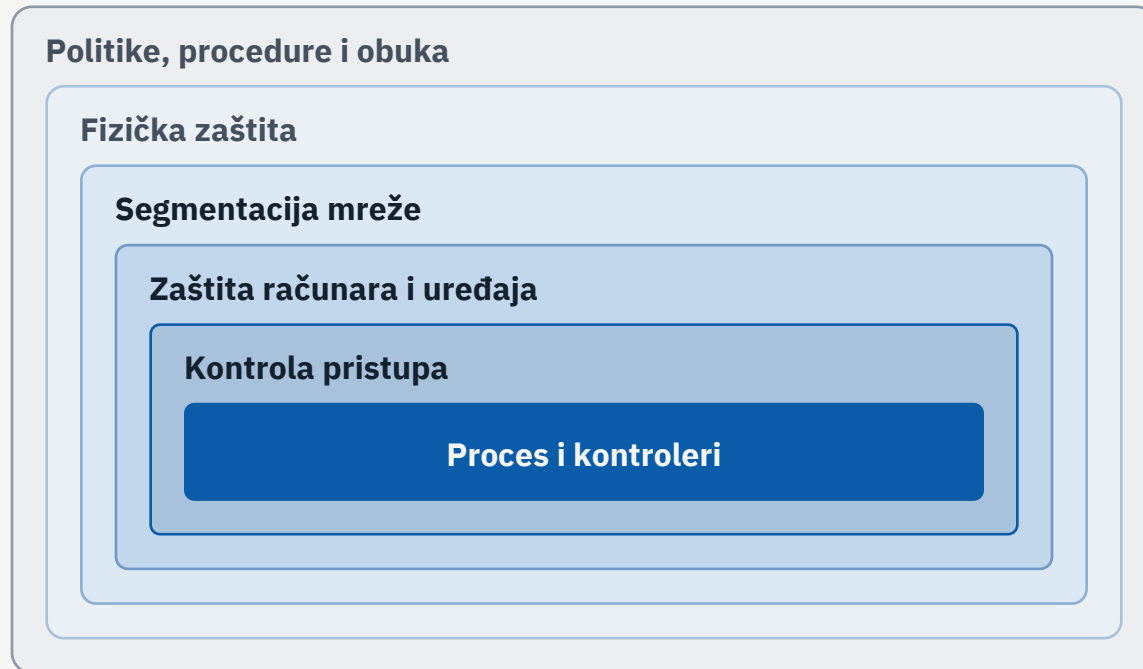
Zone i kanali prema IEC 62443



Zona grupiše resurse sa istim bezbednosnim zahtevima, a kanal je jedini dozvoljeni put komunikacije između zona. Ciljni nivoi bezbednosti (SL):



Odbrana u dubinu



Nijedna pojedinačna mera nije dovoljna. Napadač mora da savlada više nezavisnih slojeva, a svaki sloj daje novu priliku za detekciju.

Ojačavanje sistema

Uklanjanje nepotrebnih servisa, naloga i otvorenih portova.

Bela lista aplikacija

Na stanici se izvršava samo odobren softver.

Višefaktorska autentifikacija

Obavezna za udaljeni i privilegovani pristup.

Nadzor u svakom sloju

Evidencija i detekcija prate sve slojeve zaštite.

Nadzor i detekcija anomalija



Detekcija po potpisima

Prepoznaje poznate obrasce napada i malvera, ali ne i nove, do tada neviđene napade.



Mrežne anomalije

OT saobraćaj je predvidiv: isti uređaji, iste funkcije, ista učestanost. Svako odstupanje je sumnjivo.



Procesno svesna detekcija

Provera da li su izmerene vrednosti fizički usklađene sa modelom i stanjem opreme.

PRIMER PROVERE FIZIČKE USKLAĐENOSTI

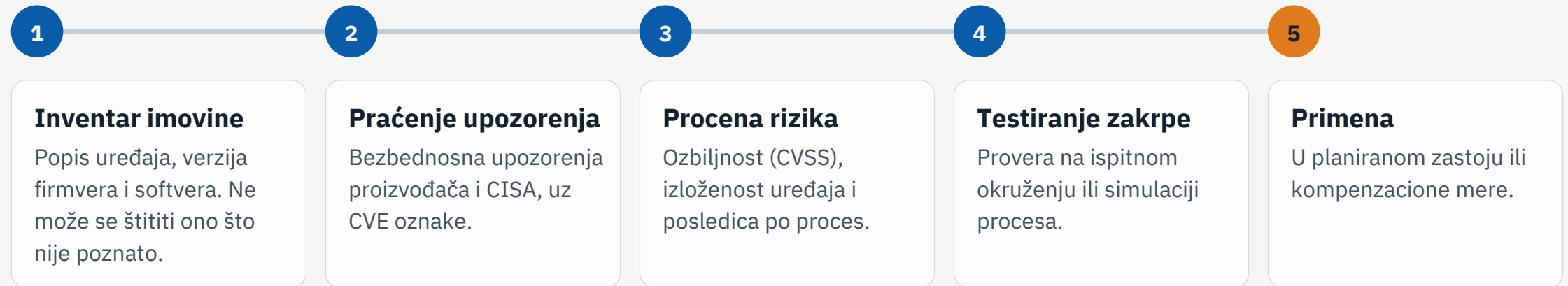
P-101.RUN = isključena FT-101 = 0 m³/s LT-101: 52 → 58 %

Anomalija: nivo raste bez ulaznog protoka



Pasivni nadzor: senzor prati kopiju saobraćaja i ne utiče na proces.

Upravljanje ranjivostima i zakrpama



Kada zavrpa nije moguća: izolacija uređaja, ograničenje saobraćaja na neophodne funkcije i pojačan nadzor.

Poznati incidenti i izvučene pouke

2010

Stuxnet

Malver je menjao logiku Siemens PLC-ova u postrojenju za obogaćivanje uranijuma, dok je operaterima prikazivao normalne vrednosti.

Pouka: integritet prikaza i logike kontrolera

2015

Ukrajinska distributivna mreža

Napadači su ukradenim nalogima preko SCADA sistema daljinski otvarali prekidače, a oko 225.000 korisnika ostalo je bez struje.

Pouka: kontrola pristupa i segmentacija

2017

Triton (Trisis)

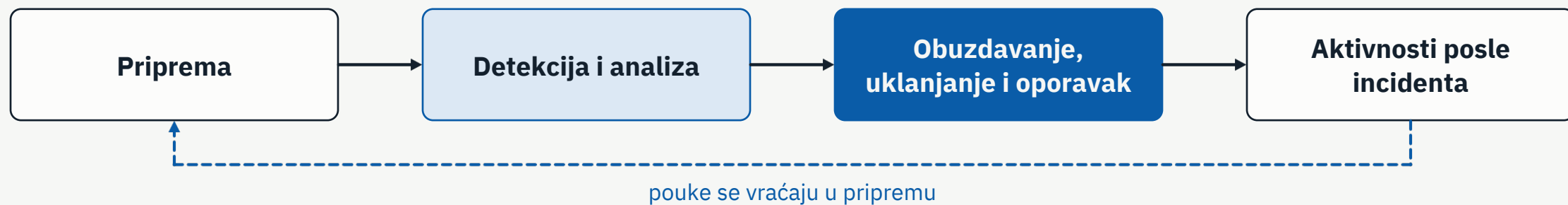
Malver usmeren na sigurnosne instrumentisane sisteme (SIS) u petrohemijskom postrojenju.

Pouka: zaštita inženjerskih stanica i bezbednosnih funkcija



Zajedničko: napad se odvijao preko legitimnih funkcija sistema — konfiguracije, naloga i komandi.

Odgovor na incidente u OT okruženju



Bezbednost procesa pre svega

Naglo isključenje sistema može biti opasnije od samog napada.

Rezervni režim rada

Ručno i lokalno upravljanje dok se sistem ne vrati u pouzdano stanje.

Forenzički tragovi

Historian, revizioni zapisi i logika kontrolera, uz usklađene vremenske oznake.

Životni ciklus prema NIST SP 800-61 Rev. 2.

Standardi i regulatorni okvir

STANDARD

IEC 62443

Bezbednost sistema industrijske automatizacije za vlasnike, integratore i proizvođače.

SMERNICE

NIST SP 800-82 Rev. 3

Preporuke za zaštitu operativne tehnologije, od arhitekture do odgovora na incidente.

OKVIR

NIST CSF 2.0

Funkcije upravljanja, identifikacije, zaštite, detekcije, odgovora i oporavka.

BAZA ZNANJA

MITRE ATT&CK for ICS

Taktike i tehnike napadača zasnovane na stvarnim incidentima.

EVROPSKA UNIJA

Direktiva NIS2

Upravljanje rizikom i prijava incidenata u energetici, vodosnabdevanju, saobraćaju i drugim sektorima.

REPUBLIKA SRBIJA

Zakon o informacionoj bezbednosti

IKT sistemi od posebnog značaja, mere zaštite i obaveštavanje o incidentima.

Od opštih pojmova do projekta SCADALattice

Opšti pojam	Realizacija u projektu SCADALattice
Proces i kontroleri (nivoi 0–1)	Simulatori procesa priključeni preko Simulator SDK-a
SCADA server	Aplikacioni servisi za tagove, komande i alarme
Drajveri i protokoli	Adapteri simulatora i reprodukcija CSV podataka
Baza tagova i kvalitet	Tipizirani tagovi sa kvalitetom, sekvencom i dva vremena
Alarmi (ISA-18.2)	Prag, histereza, kašnjenje i odvojena potvrda
HMI (ISA-101)	Web editor i režim izvršavanja procesnih ekrana
Historian	Istorija signala, vremenski upiti, agregati i izvoz
RBAC i revizija	Uloge viewer, operator, engineer i administrator, uz audit zapise
Bezbednost (IEC 62443)	Serverska autorizacija, izolacija projekata i scenariji kvarova i napada
FAT uz simulaciju	Referentni scenario i ponovljivi testovi prihvatanja

Zaključak

01 Arhitektura

Slojevi i adapteri čine sistem proširivim, a redundansa otpornim.

02 Procesi

Tag, kvalitet, alarm i komanda imaju jasnu semantiku i životni ciklus.

03 Prikazi

Dobar HMI podržava situacionu svest i ne prikazuje nepouzdan podatak kao pouzdan.

04 Konfiguracija

Verzionsana i proverljiva konfiguracija sama je bezbednosna kontrola.

05 Bezbednost

Odbrana u dubinu, segmentacija i nadzor ponašanja procesa štite sistem i kada pojedinačna kontrola zakaže.



SLEDI

Javno dostupni skupovi podataka (SWaT i drugi) i njihova primena u platformi

Pojmovnik

SCADA	Nadzor, akvizicija podataka i nadzorno upravljanje raspodeljenim procesima	Interlock	Pravilo koje zabranjuje komandu u nedozvoljenom stanju
HMI	Interfejs za praćenje procesa i izdavanje komandi	Histereza	Razlika između praga aktiviranja i praga povratka alarma
PLC / RTU	Lokalni kontroler, odnosno udaljena terminalna jedinica	DMZ	Međuzona između IT i OT mreže
Tag	Imenovana procesna promenljiva sa kvalitetom i vremenskom oznakom	RBAC	Kontrola pristupa zasnovana na ulogama
Historian	Skladište vremenskih serija procesnih podataka	FAT / SAT	Fabričko i terensko ispitivanje prihvatljivosti
SP / PV / MV	Zadata, merena i upravljačka veličina	IIoT	Industrijski internet stvari

Literatura

- [1] K. Stouffer i dr., *Guide to Operational Technology (OT) Security*, NIST SP 800-82 Rev. 3, 2023.
- [2] IEC 62443, *Security for industrial automation and control systems* (serija standarda).
- [3] ANSI/ISA-101.01-2015, *Human Machine Interfaces for Process Automation Systems*.
- [4] ANSI/ISA-18.2-2016, *Management of Alarm Systems for the Process Industries*.
- [5] ANSI/ISA-5.1, *Instrumentation Symbols and Identification*.
- [6] M. R. Endsley, „Toward a Theory of Situation Awareness in Dynamic Systems”, *Human Factors*, 37(1), 1995.
- [7] K. J. Åström, T. Hägglund, *Advanced PID Control*, ISA, 2006.
- [8] Modbus Organization, *Modbus Application Protocol Specification V1.1b3*.
- [9] R. C. Martin, *Clean Architecture*, Prentice Hall, 2017.
- [10] MITRE, *ATT&CK for Industrial Control Systems*, attack.mitre.org.
- [11] P. Cichonski i dr., *Computer Security Incident Handling Guide*, NIST SP 800-61 Rev. 2, 2012.
- [12] Direktiva (EU) 2022/2555 o merama za visok zajednički nivo sajber bezbednosti (NIS2).
- [13] SCADALattice — Tehnička specifikacija, Projekat 01, Fakultet tehničkih nauka, Novi Sad.